

ACTIVIDAD 08: LAB: FILE PATH TRAVERSAL TRAVERSAL SEQUENCES BLOCKED WITH ABSOLUTE PATH BYPASS

CNO IV (T37A): Seguridad Informática

Alumno: Alejandro García Morales
Profesor: Mtro. Servando López Contreras

Contenido

1. Nombre del Laboratorio	2
2. Nivel de Dificultad	2
3. Tipo de Explotación	2
4. Objetivo del Laboratorio	2
5. Marco Teórico y Fundamentación Técnica	2
5.1. Definición Formal de la Vulnerabilidad	2
5.2. Funcionamiento en el Sistema Operativo y Servidor Web.....	2
5.3. Análisis de Impacto en la Tríada CIA	3
5.4. Variantes Principales de Path Traversal	3
6. Procedimiento Paso a Paso y Uso Técnico de Burp Suite	3
Paso 1: Acceso e inicialización del entorno del laboratorio	3
Paso 2: Configuración del entorno de auditoría e inicio del navegador	4
Paso 3: Carga y mapeo visual de la aplicación objetivo	4
Paso 4: Inspección de peticiones HTTP y selección del vector en HTTP History	5
Paso 5: Aislamiento del parámetro vulnerable en el módulo Repeater	5
Paso 6: Inyección del Payload absoluto y exfiltración de /etc/passwd.....	6
Paso 7: Validación y confirmación del reto resuelto.....	6
7. Registro de Evidencias Técnicas	7
8. Explicación Técnica del Payload	7
Análisis de la Explotación:	7
9. Mitigación Recomendada y Principios de Defensa en Profundidad	8
9.1. Eliminar la Entrada Directa y Usar Identificadores Indirectos (Prevención IDOR)	8
9.2. Sanitización Estricta (Basename Parsing)	8
9.3. Principio de Menor Privilegio y Enjaulamiento (Hardening del Entorno)	8
10. Referencias bibliográficas.....	8

1. Nombre del Laboratorio

Lab: File path traversal, traversal sequences blocked with absolute path bypass.

Plataforma: PortSwigger Web Security Academy.

2. Nivel de Dificultad

Practitioner.

3. Tipo de Explotación

- **Categoría principal:** Inyección de secuencias de escape de directorio (File Path Traversal).
- **Mecanismo:** Evasión de filtros de sanitización (Bypass) mediante el uso de rutas absolutas para acceder a ficheros locales del sistema operativo.

4. Objetivo del Laboratorio

La aplicación bloquea secuencias de salto de directorio (como ../), pero trata el nombre de archivo suministrado de forma relativa a un directorio de trabajo predeterminado. El objetivo es evadir esta restricción suministrando una ruta absoluta directa para recuperar y extraer el contenido del archivo sensible /etc/passwd.

5. Marco Teórico y Fundamentación Técnica

5.1. Definición Formal de la Vulnerabilidad

La vulnerabilidad de File Path Traversal, clasificada bajo el estándar CWE-22 (Improper Limitation of a Pathname to a Restricted Directory), ocurre cuando el software construye una ruta de acceso basándose en la entrada del usuario sin neutralizar correctamente los elementos especiales. En el estándar OWASP Top 10:2021, esta debilidad recae en la categoría A01:2021 - Broken Access Control. En su variante de "Absolute Path Bypass", el desarrollador confía engañosamente en un filtro de lista negra que solo elimina o bloquea secuencias relativas (como ../), omitiendo validar si el usuario inserta directamente una ruta absoluta.

5.2. Funcionamiento en el Sistema Operativo y Servidor Web

En muchos lenguajes de programación del backend (como Java, PHP o Python), cuando una función que resuelve rutas de archivos intenta concatenar un "directorio base estático" con un "nombre de archivo suministrado por el usuario", ocurre un comportamiento crítico a nivel de la API del sistema:

Si la entrada del usuario comienza con el carácter de separación de directorios raíz / (indicando una ruta absoluta), la función descarta automáticamente el directorio base y resuelve el archivo partiendo directamente desde la raíz del sistema operativo.

5.3. Análisis de Impacto en la Tríada CIA

- **Confidencialidad (Impacto Crítico):** Permite a un atacante no autenticado leer archivos arbitrarios del sistema, tales como `/etc/passwd`, obteniendo visibilidad sobre los usuarios del sistema operativo (root, daemon, www-data, etc.).
- **Integridad (Impacto Nulo a Alto):** En vectores de solo lectura, la integridad no se altera. Sin embargo, si existen funciones de subida de archivos (Upload), este bypass permitiría sobrescribir archivos del sistema.
- **Disponibilidad (Impacto Medio a Potencial):** La lectura arbitraria de descriptores de archivos virtuales (`/dev/urandom`) puede ocasionar el agotamiento de recursos del servidor.

5.4. Variantes Principales de Path Traversal

El vector evaluado en esta práctica corresponde a la variante Absolute Path Bypass. A diferencia del "Simple Case" (donde no existen filtros), aquí el servidor sí implementa una defensa (bloqueo de `../`), la cual resulta ineficaz porque el analista cambia su estrategia, abandonando la navegación jerárquica y apuntando directamente al destino absoluto.

6. Procedimiento Paso a Paso y Uso Técnico de Burp Suite

Paso 1: Acceso e inicialización del entorno del laboratorio

Se ingresa al portal de PortSwigger Web Security Academy en la sección del laboratorio "File path traversal, traversal sequences blocked with absolute path bypass". Tras analizar la premisa del nivel Practitioner, se inicializa el entorno haciendo clic en el botón naranja "Access the lab".

The screenshot shows the lab interface with the title "Lab: File path traversal, traversal sequences blocked with absolute path bypass". Below the title, there is a "PRACTITIONER" badge and a "LAB" button with a checkmark and the word "Solved". A red arrow points to the right. The text describes the lab: "This lab contains a path traversal vulnerability in the display of product images. The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory. To solve the lab, retrieve the contents of the `/etc/passwd` file." At the bottom, there is an orange button with a flask icon and the text "ACCESS THE LAB".

Paso 2: Configuración del entorno de auditoría e inicio del navegador

Se abre Burp Suite Community Edition y se navega a la pestaña Proxy > HTTP history. Estando el historial vacío, se hace clic en "Open browser" para lanzar el navegador preconfigurado de intercepción que registrará el tráfico hacia la aplicación vulnerable.



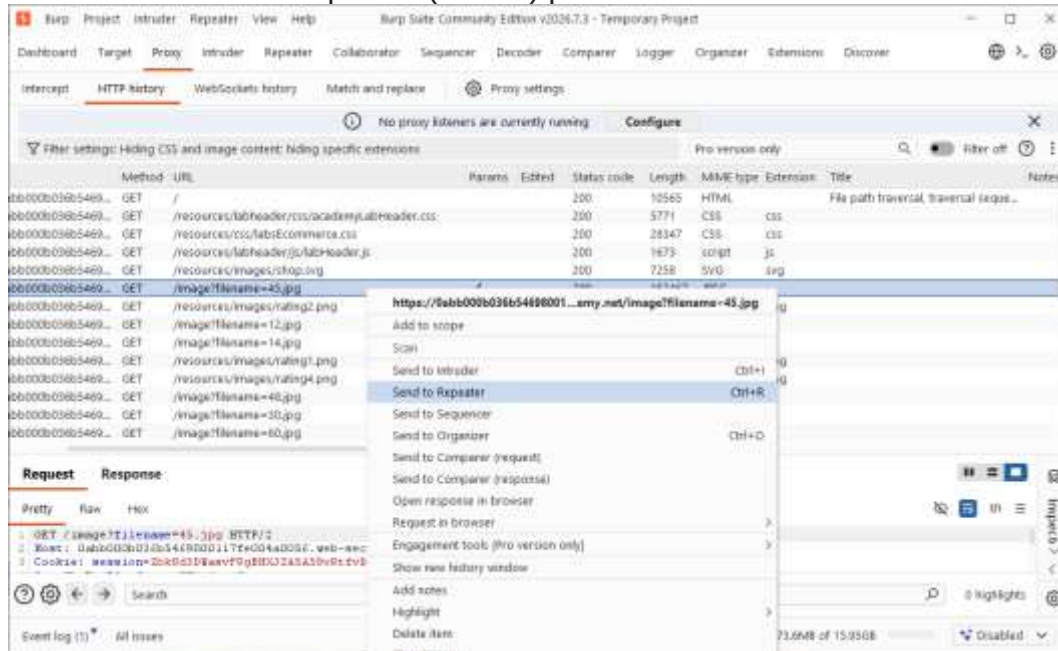
Paso 3: Carga y mapeo visual de la aplicación objetivo

Se visualiza la tienda en línea ("WE LIKE TO SHOP") y se corrobora que las imágenes estáticas de los productos cargan correctamente dentro del navegador gestionado por Burp.

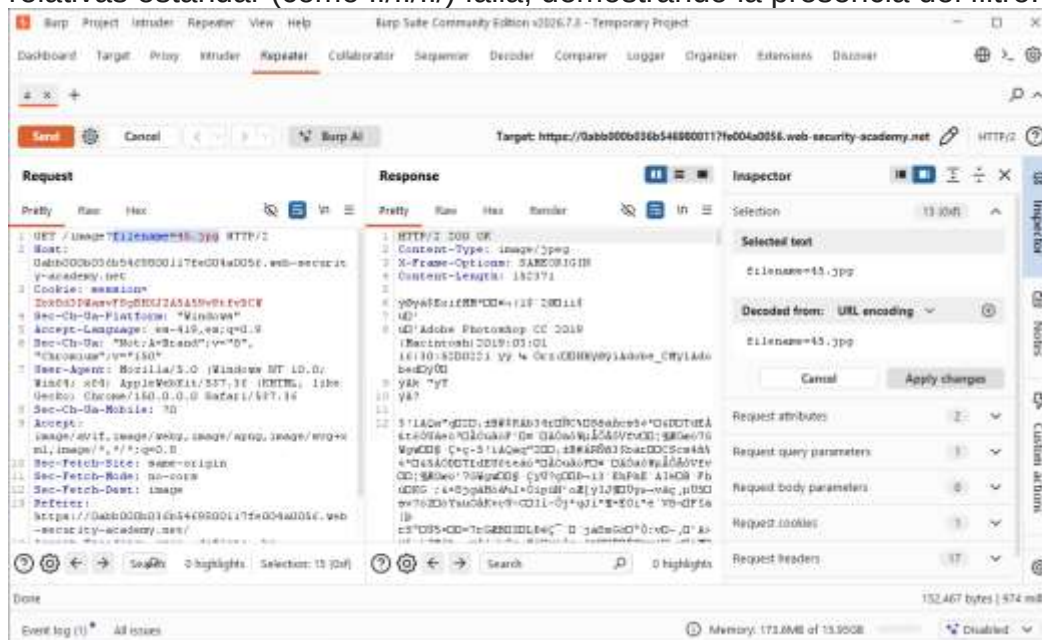


Paso 4: Inspección de peticiones HTTP y selección del vector en HTTP History

Al revisar el historial HTTP capturado, se identifica que la carga de las imágenes depende de peticiones GET. Se localiza una de estas solicitudes (por ejemplo, GET /image?filename=45.jpg). Se selecciona esta petición y, mediante clic derecho, se envía al módulo Repeater (Ctrl+R) para su análisis.

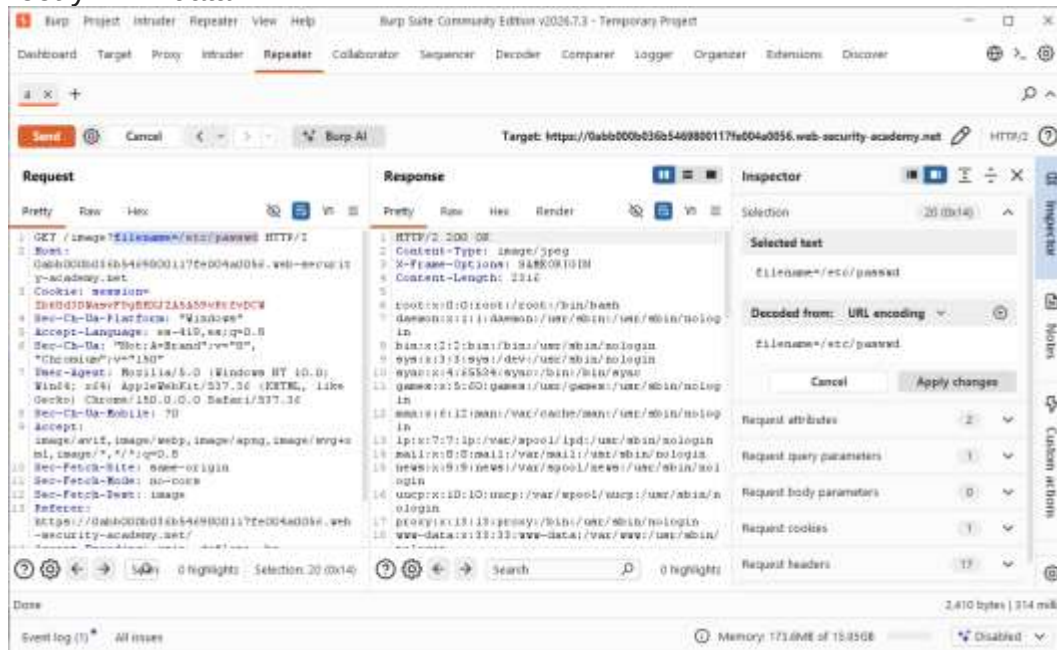


Paso 5: Aislamiento del parámetro vulnerable en el módulo Repeater
Dentro de Repeater, se identifica el parámetro objetivo filename=45.jpg. Se corrobora que la aplicación responde correctamente con la imagen solicitada (código 200 OK y Content-Type: image/jpeg). Un intento de inyectar secuencias relativas estándar (como ../../..) falla, demostrando la presencia del filtro.



Paso 6: Inyección del Payload absoluto y exfiltración de /etc/passwd

Se evade el filtro sustituyendo la ruta relativa por un payload absoluto. Se reemplaza 45.jpg por /etc/passwd. Al enviar la petición modificada (GET /image?filename=/etc/passwd), el servidor devuelve un código de estado HTTP/2 200 OK. En el cuerpo de la respuesta se obtiene exitosamente la estructura en texto plano del archivo /etc/passwd, exponiendo cuentas locales de Linux como root y www-data.



Paso 7: Validación y confirmación del reto resuelto

Se regresa a la interfaz de navegación del laboratorio en PortSwigger y se observa que el banner superior ha sido actualizado a "Solved" / "Lab Solved", confirmando la explotación exitosa de la vulnerabilidad y la completitud de la prueba.

Lab: File path traversal, traversal sequences blocked with absolute path bypass

PRACTITIONER

LAB ✓ Solved

This lab contains a path traversal vulnerability in the display of product images.

The application blocks traversal sequences but treats the supplied filename as being relative to a default working directory.

To solve the lab, retrieve the contents of the `/etc/passwd` file.

[ACCESS THE LAB](#)

7. Registro de Evidencias Técnicas

ID Evidencia	Elemento Requerido	Descripción Técnica
EVID-01	Inicialización del entorno	Interfaz de inicio de PortSwigger con la etiqueta Practitioner y el botón Access the lab.
EVID-02	Configuración del Proxy	Vista de Proxy > HTTP history vacío ("HTTP history is empty") y el botón Open browser.
EVID-03	Aplicación objetivo	Interfaz web de la tienda "WE LIKE TO SHOP" renderizada bajo la auditoría.
EVID-04	Interceptación de tráfico	Identificación de GET /image?filename=45.jpg y selección de la opción "Send to Repeater" en el historial HTTP.
EVID-05	Localización del vector	Identificación del parámetro filename=45.jpg en Repeater con respuesta image/jpeg.
EVID-06	Inyección y Exfiltración	Petición modificada a filename=/etc/passwd y respuesta HTTP 200 con el listado de usuarios del sistema Linux.
EVID-07	Acreditación de resolución	Confirmación visual del estado "Lab Solved" en color verde dentro de la plataforma.

8. Explicación Técnica del Payload

Payload Utilizado:

/etc/passwd

Análisis de la Explotación:

1. **Punto de Inyección:** Parámetro filename en la ruta /image.
2. **Ausencia de Secuencias Relativas:** El payload no utiliza ningún fragmento ../ debido a que el servidor cuenta con una regla explícita que bloquea o elimina estas cadenas ("traversal sequences blocked").
3. **Prioridad de Resolución de Ruta:** El backend concatena el directorio de trabajo predeterminado (ej. /var/www/images/) con el input del usuario (/etc/passwd).
4. **Por qué funciona el Bypass:** La función a nivel de sistema operativo encargada de abrir el archivo interpreta que la cadena provista por el usuario comienza con / (la raíz de Unix/Linux). Según el estándar de las APIs de manejo de rutas en la mayoría de los lenguajes, cuando se proporciona un "Absolute Path", cualquier prefijo o directorio base anterior se anula e ignora. En consecuencia, el servidor no busca /var/www/images/etc/passwd (lo cual fallaría), sino que va directamente a la raíz absoluta del disco y abre /etc/passwd con éxito, devolviendo su contenido en la respuesta HTTP.

9. Mitigación Recomendada y Principios de Defensa en Profundidad

9.1. Eliminar la Entrada Directa y Usar Identificadores Indirectos (Prevención IDOR)

El mecanismo defensivo más efectivo es no permitir que el usuario defina nombres de archivos. La aplicación debe almacenar los nombres reales en una base de datos de manera segura y exponer al usuario solo un identificador alfanumérico seguro (ej. GET /image?id=9a2b). El servidor consulta la base de datos con ese id y devuelve el recurso correspondiente, cortando de raíz la inyección de rutas.

9.2. Sanitización Estricta (BaseName Parsing)

Si por diseño arquitectónico es obligatorio recibir nombres de archivo, el desarrollador no debe confiar en "listas negras" de caracteres como bloqueos de ../ o filtros débiles. Debe emplearse una función nativa de extracción del nombre base. Esto garantiza que si el usuario envía /etc/passwd o ../../etc/passwd, la función extraerá y operará únicamente con la palabra passwd, anulando por completo la navegación por directorios.

9.3. Principio de Menor Privilegio y Enjaulamiento (Hardening del Entorno)

A nivel de sistema operativo, el usuario de servicio bajo el cual corre el servidor web debe ser despojado de todos los permisos de lectura en directorios fuera de la carpeta estricta de la aplicación (/var/www/html/). Además, el proceso debe aislarse utilizando contenedores y jaulas de raíz complementados con perfiles de seguridad como AppArmor o SELinux, de forma que el servidor web "crea" que el directorio de la aplicación es la raíz total del disco duro, haciendo físicamente imposible escalar a la verdadera carpeta /etc/ del servidor host.

10. Referencias bibliográficas

- MITRE Corporation. (2024). *CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal')*. Common Weakness Enumeration.
- Open Web Application Security Project. (2021). *A01:2021 - Broken Access Control*. OWASP Top 10.
- PortSwigger. (s. f.). *Lab: File path traversal, traversal sequences blocked with absolute path bypass*. PortSwigger Web Security Academy.